

Temă de Proiect:

Platformă Web Securizată pentru OCR Medical & CI/CD Guvernat de AI

1. Prezentarea Generală a Proiectului

Obiectivul acestei teme este dezvoltarea unei platforme web ultra-securizate pentru procesarea documentelor medicale. Sistemul va prelua imagini și documente medicale prin intermediul unui broker MQTT securizat, le va procesa folosind un motor de recunoaștere optică a caracterelor (OCR) și va genera rapoarte dinamice.

Deoarece această aplicație gestionează informații sensibile privind sănătatea pacienților (PHI - Patient Health Information), trebuie dezvoltată utilizând un model de securitate bazat pe **Analiza Amenințărilor și Evaluarea Riscurilor (TARA)**. În plus, ciclul de dezvoltare trebuie gestionat de o **Arhitectură CI/CD**, este acceptabila opțiunea unui **CICD asistat de AI și Optimizat pentru Securitate**, utilizând agenți AI pentru testare autonomă și remedierea vulnerabilităților, menținând în același timp un control strict, cu supervizare umană (human-in-the-loop) ce trebuie demonstrat că este determinist.

2. Funcționalități Principale ale Aplicației Web

A. Preluarea Datelor & API-uri

- **Broker MQTT:** Implementați un broker MQTT securizat pentru a primi imaginile și documentele medicale. Implementați limite pentru dimensiunea pachetelor de date (payload) și limitarea ratei de cereri (rate limiting) pentru a preveni atacurile DoS.
- **Endpoint-uri Web:** Dezvoltați API-uri RESTful sau GraphQL securizate pentru interfața utilizatorului (frontend).

B. Procesare OCR Inteligentă

- **Schemă de ieșire JSON:** Integrați un motor OCR (ex. EasyOCR, DeepSeek) care să returneze datele extrase (Nume Pacient, medicație, Data Expirării) într-un format JSON standardizat, în locul unui simplu text brut.
- **Prag de Încredere (Confidence Thresholding):** Implementați o logică care marchează orice dată extrasă cu un scor de încredere sub 95% pentru o revizuire manuală (umană) în interfață.

C. Raportare Dinamică și Stocare

- **Bază de date:** Stocați datele structurate în siguranță într-o bază de date relațională (ex. PostgreSQL).
 - **Rapoarte Extensibile:** Construiți un generator dinamic de rapoarte capabil să producă:
 - Alerte de conformitate/expirare (ex. reînnoiri de controale).
 - Seturi de date anonimizate (ascunzând automat datele PHI pentru rapoarte de cercetare).
 - Valori de performanță a sistemului (latența procesării, ratele de succes OCR).
 - Este relevant să aflăm din rapoarte informații precum câte persoane și-au făcut medicina muncii în ultima lună, cui îi expiră medicina muncii luna viitoare, câte persoane au făcut medicina muncii etc.
-

3. Cerințe de Securitate a Aplicației (Modelul TARA)

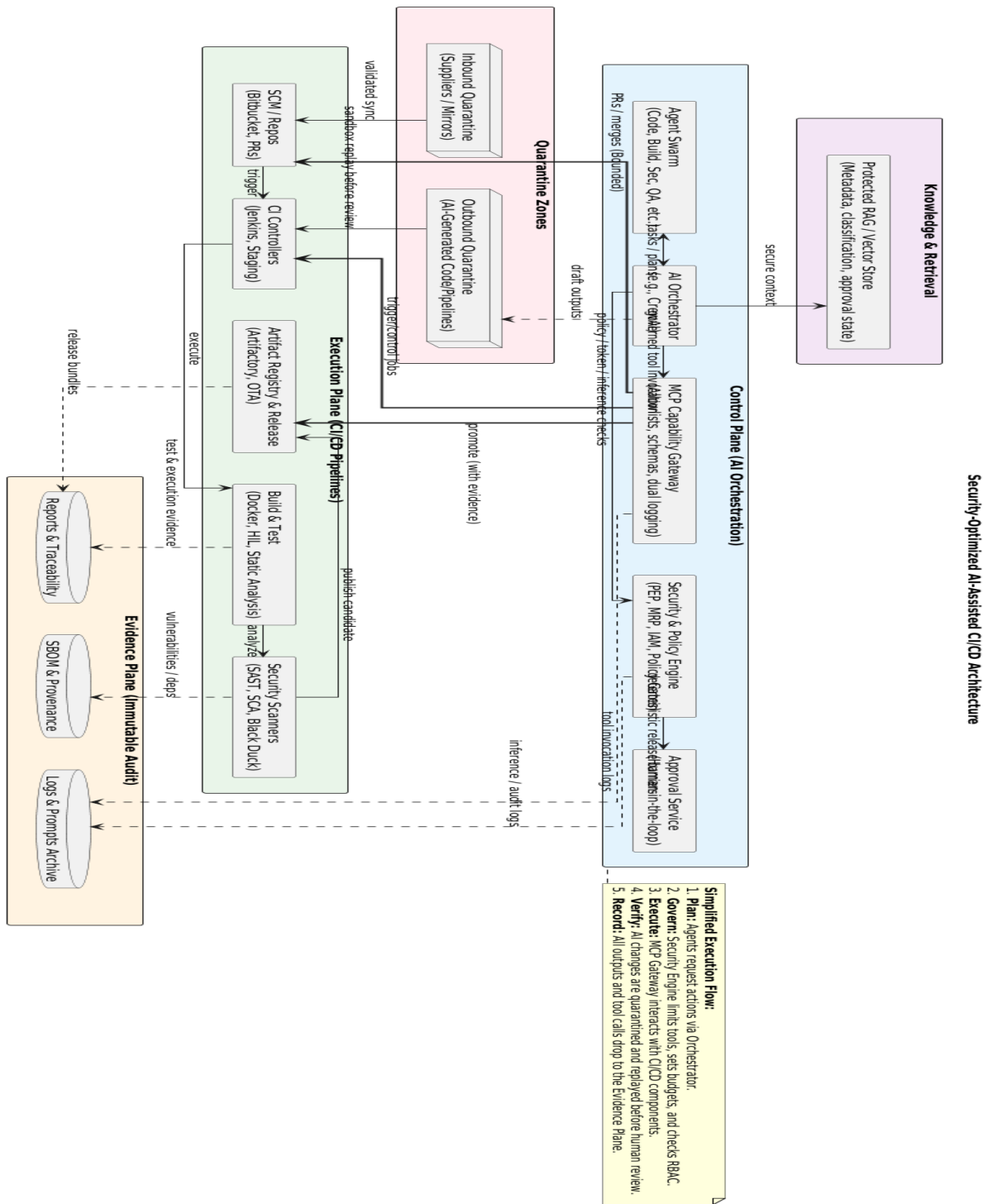
- **Izolarea Procesării Imaginilor (Sandboxing):** Motorul OCR trebuie să ruleze într-un mediu strict izolat, fără privilegii (ex. un container Docker "distroless" sau un sandbox gVisor) pentru a preveni executarea de la distanță a codului (RCE) prin imagini manipulate malițios.
 - **Protecția Datelor:** Toate informațiile medicale sensibile (PHI) trebuie criptate în repaus (at rest) în baza de date. Toate comunicațiile interne între microservicii (Web <-> Bază de Date <-> OCR) trebuie să utilizeze protocolul TLS.
 - **Controlul Accesului:** Implementați un control robust al accesului bazat pe roluri (RBAC) folosind JWT sau autentificare bazată pe sesiuni, pentru a vă asigura că utilizatorii văd doar datele pentru care au autorizație.
-

4. Ecosistemul CI/CD și Arhitectura de Guvernanță AI

Fluxul (pipeline-ul) de dezvoltare și implementare trebuie să respecte **Arhitectura CI/CD** și este acceptabilă opțiunea unui **CICD asistat de AI și Optimizat pentru Securitate**, furnizată în diagrama anterioară.

Indiferent de forma sub care se prezintă CI/CD-ul este interzisa integrarea modificărilor fără a trece printr-un gateway de securitate, unit-teste pentru funcționalitatea nou adăugată, raport de static code analysis fără noi findings introduse alte teste de calitate relevante funcționalității respective.

O propunere pentru un sistem CI/CD asistat de AI este următoarea:



Planul 1: Cunoaștere și Extragere (Knowledge & Retrieval)

- **Stocare Vectorială Protejată:** Mențineți o bază de date RAG (Retrieval-Augmented Generation) securizată, care conține metadatele proiectului, schemele de securitate și ghidurile arhitecturale aprobate, pentru a oferi context agenților AI.

Planul 2: Planul de Control (Orchestrare AI)

- **Roi de Agenți (Agent Swarm) & Orchestrator:** Utilizați agenți AI pentru a gestiona recenziile de cod, sarcinile de compilare (build) și analiza de securitate.
- **Gateway de Capabilități MCP & Motor de Securitate:** Toate apelurile de instrumente ale AI-ului trebuie să treacă printr-un gateway de permisiuni (Allowlist). Motorul de Securitate limitează instrumentele pe care le poate folosi AI-ul și impune regulile RBAC.
- **Serviciu de Aprobare:** Implementați o poartă strictă de tip "Supervizare Umană". Agenții AI nu pot lansa software în mod autonom; ei pot doar propune cod/PR-uri.

Planul 3: Zone de Carantină

- **Carantină de leșire (Outbound):** Orice cod sau actualizare de pipeline generată autonom de AI (ex. un patch pentru o vulnerabilitate găsită) trebuie plasată într-un sandbox. Trebuie rulată și testată în siguranță înainte ca un dezvoltator uman să vadă cererea de modificare (Pull Request).

Planul 4: Planul de Execuție (Pipeline-ul CI/CD)

- **SCM & Repozitoare:** Utilizați soluții standard de control al versiunilor (ex. GitHub, GitLab, Bitbucket).
- **Build, Testare și Analiză:** Implementați testare automată concentrată pe acoperirea de 100% a ramurilor (branch coverage) pentru limitele critice de securitate.
- **Scanere de Securitate:** Integrați SAST (Analiză Statică), DAST și Fuzzere pentru API. Rezultatele trebuie exportate obligatoriu în format SARIF pentru a fi integrate într-un panou de control centralizat.

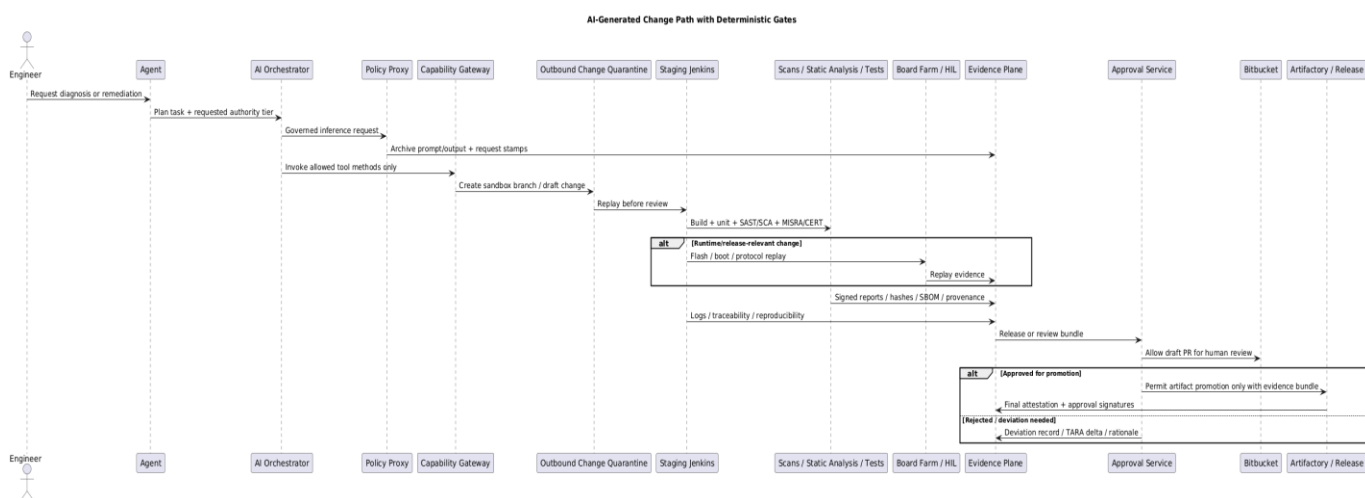
Planul 5: Planul de Dovezi (Audit Imutabil)

- **SBOM & Proveniență:** Generați automat un "Software Bill of Materials" (SBOM - standardul CycloneDX sau SPDX) la compilare, pentru a urmări toate dependențele (framework-uri web, biblioteci OCR).
- **Arhivă de Jurnale (Logs) & Prompt-uri:** Mențineți o arhivă imutabilă cu toate prompt-urile AI, deciziile luate, instrumentele folosite și dovezile testelor, pentru audit și trasabilitate.

5. Rezumatul Fluxului de Execuție

Când dezvoltați funcționalități sau reparați bug-uri, urmați acest flux asistat de AI:

1. **Planificare (Plan):** Agenții AI solicită acțiuni prin intermediul Orchestratorului.
2. **Guvernare (Govern):** Motorul de Securitate verifică politicile și restricționează acțiunile neautorizate ale AI-ului.
3. **Execuție (Execute):** Gateway-ul MCP interacționează cu instrumentele CI/CD (ex. Jenkins, Scanere).
4. **Verificare (Verify):** Modificările AI sunt puse în carantină și simulate înainte de revizuirea umană.
5. **Înregistrare (Record):** Toate rezultatele și apelurile de instrumente sunt arhivate în Planul de Dovezi.



6. Funcționalități Client-Side (Dispozitive Embedded / Mobile)

Aceste funcționalități vizează dispozitivele de la marginea rețelei (edge) care interacționează direct cu documentele fizice:

- **Captură de Imagini Utilizând Camera Dispozitivului:** Folosirea camerei unui telefon mobil sau a unui sistem embedded (ex. ESP32-CAM) pentru a capta imagini sau a scana documente medicale.
- **Transmisie Securizată prin MQTT folosind mTLS:** Transmiterea sigură a imaginilor sau documentelor către server folosind protocolul MQTT peste Mutual TLS (mTLS). Se vor utiliza biblioteci de specialitate (ex. paho-mqtt pentru client, mosquitto pe server).
- **Mod Offline (Stocare Locală):** Implementarea unui mecanism de failover: stocarea locală a imaginilor (pe card SD/memorie flash) dacă serverul nu este accesibil și reîncercarea automată a transmisiei la restabilirea conexiunii.
- **Actualizări de Firmware OTA (Bonus Opțional):** Implementarea unui mecanism de actualizare Over-The-Air (OTA) a firmware-ului pentru dispozitivele embedded, declanșat prin intermediul unui mesaj MQTT sau a unui endpoint HTTP.